Cavallin Bruno W20D4 Progetto Finale

Security Operation

Progetto di sicurezza per una piattaforma e-commerce

Introduzione

Questo documento presenta una progettazione ad alto livello dell'architettura di sicurezza di una piattaforma e-commerce,anche detto HLD (High-Level Design).

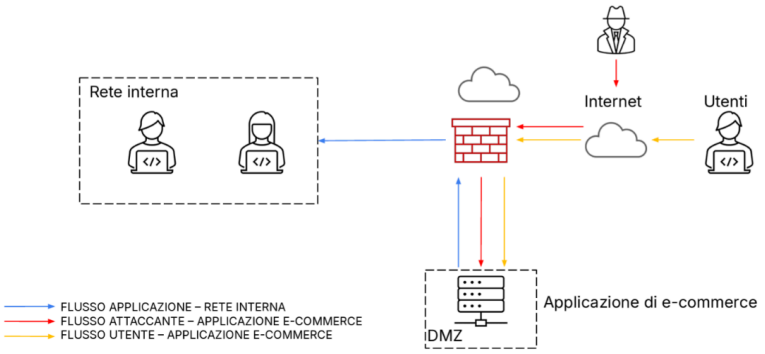
La situazione iniziale presenta un server e-commerce esposto nella DMZ. La persona con il cappello nella figura rappresenta l'attaccante esterno. Il suo obiettivo è sfruttare l'applicazione e, se il server viene compromesso, tentare un movimento laterale verso la rete interna.

L'obiettivo non è creare una sicurezza perfetta, perché il rischio zero non esiste. L'obiettivo è costruire una soluzione più sicura e controllabile rispetto alla situazione iniziale, mantenendo un preventivo compreso tra 25.000 € e 35.000 €. La valutazione considera la riservatezza, l'integrità e la disponibilità dei dati e dei servizi. In modo semplificato, il rischio può essere considerato come probabilità dell'evento × impatto del danno.

(Il budget riguarda esclusivamente la sicurezza dell'infrastruttura: il sito e-commerce e i suoi normali costi di gestione sono già esclusi dal preventivo).

Architettura di rete:
L'applicazione di e-commerce deve essere disponibile per gli utenti tramite Internet per effettuare acquisti sulla piattaforma.

La rete interna è raggiungibile dalla DMZ per via delle policy sul firewall, quindi se il server in DMZ viene compromesso potenzialmente un attaccante potrebbe raggiungere la rete interna.

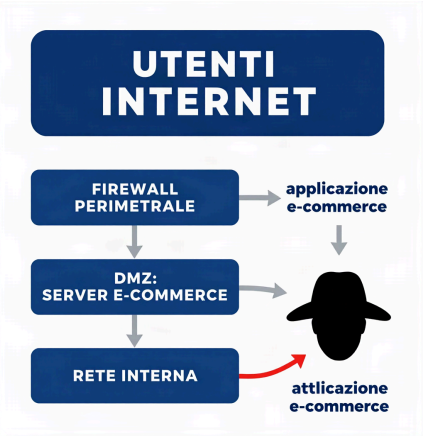


1. Situazione iniziale e problemi principali

Nell'architettura iniziale il traffico degli utenti Internet raggiunge il server e-commerce nella DMZ. Un attaccante può provare a sfruttare vulnerabilità dell'applicazione, come SQL Injection o XSS. Se il server viene compromesso, può anche tentare un movimento laterale verso la rete interna.

I problemi principali sono:

- assenza di un WAF dedicato davanti all'applicazione;
- rischio di SQL Injection e Cross-Site Scripting;
- possibile indisponibilità del sito in caso di DDoS;
- collegamenti tra DMZ e rete interna da limitare meglio;
- assenza di una procedura chiara per isolare un server infetto;
- log e allarmi non raccolti in modo centralizzato.



2. Primo scenario

Prevenzione degli attacchi web e risposta al malware

Il primo scenario unisce il punto 1, relativo alla protezione da SQL Injection e XSS, e il punto 3, relativo alla risposta nel caso in cui il server e-commerce venga infettato.

Questi due aspetti possono coesistere nella stessa architettura: il WAF cerca di impedire l'attacco iniziale, mentre EDR, firewall e VLAN di quarantena intervengono se il server viene comunque compromesso.

2.1 Protezione da SQL Injection e XSS

Davanti al server e-commerce viene inserito un **WAF (Web Application Firewall)**. Il WAF controlla le richieste HTTP e blocca i payload riconducibili ad attacchi SQL Injection e XSS.

Il **WAF** non è l'unica protezione. L'applicazione deve utilizzare anche:

- query parametrizzate e prepared statement;
- validazione degli input lato server;
- output encoding;
- Content Security Policy;
- cookie con attributi **HttpOnly, Secure e SameSite**;
- aggiornamento di framework, librerie e server;
- account applicativi con privilegi minimi sul database.

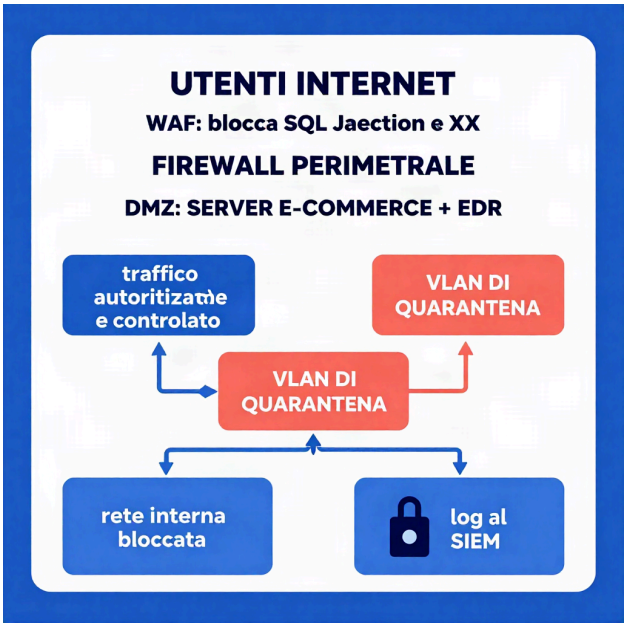
2.2 Risposta alla presenza di malware

La risposta deve distinguere tra contenimento immediato e ripristino successivo. Prima si limita la propagazione; in seguito si analizza l'incidente e si ripristina il servizio da una base verificata.

Se il server e-commerce viene infettato, la priorità è impedire che il malware raggiunga la rete interna. Non si deve lasciare il server libero di comunicare con tutti i sistemi.

La procedura prevista è:

1. rilevare l'evento tramite EDR, firewall o SIEM;
2. spostare il server in una VLAN di quarantena;
3. bloccare il traffico verso la rete interna;
4. bloccare il collegamento del server compromesso al database e alla rete interna; eventuali comunicazioni in uscita vengono consentite solo se indispensabili, limitate e monitorate;
5. raccogliere log e indicatori di compromissione;
6. controllare eventuali tentativi di movimento laterale;
7. cambiare le credenziali eventualmente esposte;
8. ripristinare il server da un backup verificato;
9. reinserire il sistema in produzione dopo i controlli.



2.3 Risultato dello scenario 1

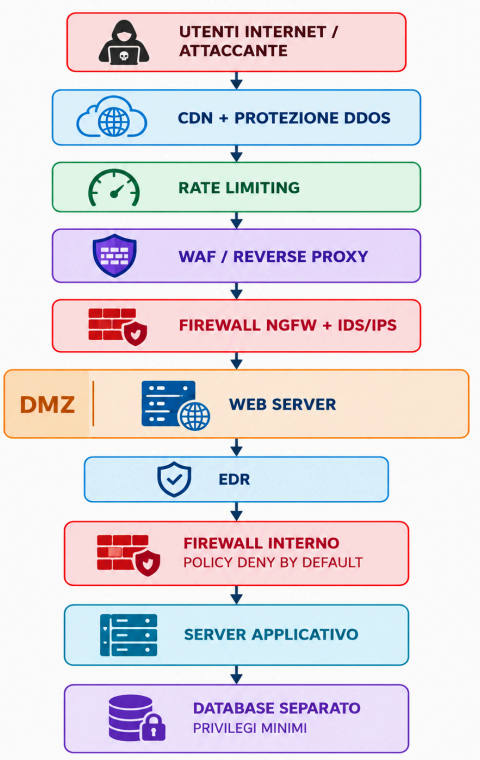
Questa soluzione riduce il rischio di attacco all'applicazione e limita i danni nel caso in cui l'attaccante riesca comunque a compromettere il server. Il server non viene considerato automaticamente affidabile solo perché si trova nella DMZ. La misura principale è il contenimento: si blocca la propagazione verso la rete interna, mentre eventuali comunicazioni in uscita vengono mantenute solo se necessarie, limitate e monitorate per raccogliere indicatori utili all'analisi.

3. Secondo scenario: soluzione unica dei punti 1, 2 e 3

Protezione web, DDoS e risposta agli incidenti

Il secondo scenario unisce tutti i punti della traccia in un'unica architettura:

- il **punto 1** viene gestito tramite WAF e sicurezza applicativa;
- il **punto 2** viene gestito tramite CDN, protezione DDoS e rate limiting;
- il **punto 3** viene gestito tramite EDR, SIEM, firewall e quarantena.



3.1 Funzionamento della soluzione

1. La CDN e il servizio anti-DDoS filtrano il traffico prima che raggiunga la rete aziendale. La protezione locale non può risolvere da sola un attacco che saturi la connessione Internet.
2. Il rate limiting limita il numero di richieste provenienti da una singola sorgente o da comportamenti anomali.
3. Il WAF analizza le richieste HTTP e blocca attacchi web conosciuti.
4. Il firewall NGFW controlla le connessioni verso la DMZ e applica le regole di sicurezza.
5. L'EDR controlla il web server e può segnalarne o isolarne la compromissione.
6. Il firewall interno permette solo le comunicazioni necessarie tra web server, application server e database.
7. Il database accetta connessioni esclusivamente dal server applicativo autorizzato.
8. In caso di malware, il server viene spostato in una VLAN di quarantena.
9. I log vengono inviati al SIEM per essere correlati e interpretati.

3.2 Impatto economico del DDoS

Il sito produce in media **1.500 € al minuto**. In caso di indisponibilità per 10 minuti:

```
1.500 € x 10 minuti = 15.000 €
```

La perdita diretta stimata è quindi di 15.000 €. Il danno reale può aumentare considerando carrelli abbandonati, perdita di fiducia, richieste al supporto e danno reputazionale.

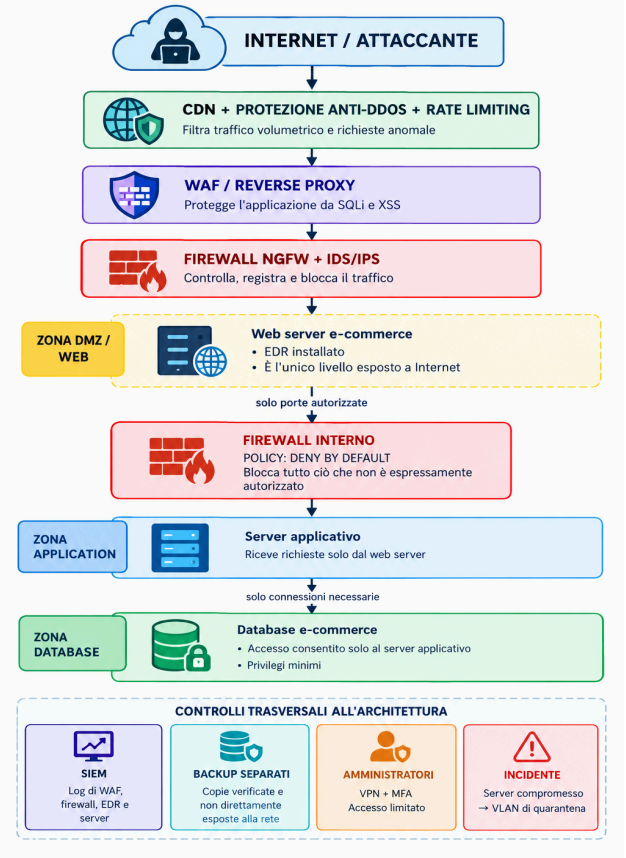
La protezione DDoS non garantisce che ogni attacco venga bloccato al cento per cento, ma riduce la probabilità che il traffico malevolo raggiunga direttamente la rete aziendale. La CDN filtra soprattutto il traffico volumetrico, mentre il rate limiting e il WAF intervengono sugli attacchi HTTP e sui comportamenti anomali a livello applicativo.

4. Progetto finale integrato

Configurazione più sicura e aggressiva entro il budget

La configurazione finale aumenta il livello di protezione rispetto alla situazione di partenza. Sono state selezionate soltanto le misure più utili e realistiche per questo caso, in modo da mantenere l'architettura efficace e sostenibile.

La protezione viene organizzata in livelli:



Le regole più importanti sono:

- solo il livello web è esposto a Internet;
- il web server comunica con il server applicativo solo sulle porte necessarie;
- il database comunica solo con il server applicativo;
- la **DMZ** non può raggiungere liberamente la rete interna;
- il firewall utilizza una policy deny by default **sia in ingresso che in uscita (Ingress & Egress Filtering)** per impedire al malware di aprire connessioni verso server esterni (*Command & Control*);
- gli amministratori utilizzano VPN e MFA;
- i backup sono separati dalla rete produttiva;
- un sistema compromesso può essere isolato senza spegnere immediatamente tutta l'infrastruttura.

Non elimina il rischio, ma rende più difficile l'attacco e limita il movimento laterale.

5. Security Operation e Threat Intelligence

Il monitoraggio e la gestione degli eventi sono fondamentali per rendere efficaci i sistemi di difesa. I log generati da WAF, Firewall, EDR e server vengono inviati in modo centralizzato al **SIEM**, che li analizza in tempo reale e mette in correlazione le segnalazioni sospette per individuare tempestivamente eventuali attacchi in corso.

A supporto del SIEM interviene la **Threat Intelligence**, che fornisce dati aggiornati sulle minacce esterne (come indirizzi IP malevoli o firme di malware) e permette di classificare il comportamento dell'attaccante.

Il processo di risposta si sviluppa in quattro passaggi fondamentali:

- **Raccolta dei log e degli allarmi:** i vari dispositivi inviano continuamente i dati di sicurezza al sistema centrale.
- **Centralizzazione e correlazione:** il SIEM analizza gli eventi e scarta i falsi positivi.
- **Analisi dell'evento:** l'allarme viene arricchito con le informazioni della Threat Intelligence per comprenderne la gravità.
- **Decisione ed esecuzione:** in base al tipo di minaccia, si decide se **bloccare** il traffico malevolo, isolare il server compromesso in **quarantena** o procedere con il **ripristino** del sistema da un backup sicuro.

L'intero ciclo di gestione degli incidenti si completa infine attraverso sei fasi operative: la **preparazione** delle difese, l'**identificazione** dell'attacco, il **contenimento** dei danni, l'**eliminazione** della causa, il **ripristino** del servizio e l'**analisi finale** per migliorare ulteriormente la sicurezza dell'infrastruttura.

6. Preventivo di sicurezza

Il preventivo comprende soltanto gli elementi necessari. Non sono inclusi i costi ordinari del sito e-commerce, dello sviluppo applicativo o dell'infrastruttura già esistente: il budget riguarda esclusivamente le misure di sicurezza progettate.

Componente	Funzione	Costo stimato
Firewall NGFW con IDS/IPS	Controllo del traffico e segmentazione	7.500 €
WAF / Reverse Proxy	Protezione da SQL Injection e XSS	4.500 €
CDN e protezione DDoS	Disponibilità e filtraggio del traffico	5.000 €
EDR per il web server	Rilevamento e isolamento malware	3.500 €
SIEM e raccolta log	Monitoraggio e correlazione eventi	3.000 €
Backup separati e test di ripristino	Recupero dopo un incidente	3.000 €
Configurazione, test e documentazione	Regole, segmentazione e procedure	4.500 €
Totale		31.000 €

Distribuzione del budget: la quota maggiore è destinata a firewall, WAF e protezione DDoS, perché rappresentano le prime barriere verso Internet. Le restanti risorse finanziano rilevamento, ripristino e configurazione.

7. Conclusione

Le componenti possono coesistere perché svolgono funzioni diverse e complementari:

- il primo scenario protegge l'applicazione e gestisce il malware;
- il secondo unisce protezione web, DDoS e incident response;
- il progetto finale rafforza la segmentazione e limita le comunicazioni tra i diversi livelli.

In conclusione, il progetto dimostra come la sicurezza di un'infrastruttura non dipenda da un singolo strumento infallibile, ma dall'applicazione coerente del principio di **Defense in Depth** (difesa in profondità). Consapevole che il "rischio zero" non esiste, l'architettura proposta sposta il focus dalla sola prevenzione perimetrale alla capacità di rilevamento tempestivo, contenimento e ripristino.

L'integrazione coordinata di CDN, WAF, EDR, SIEM e segmentazione di rete riduce drasticamente la superficie d'attacco e impedisce il movimento laterale di eventuali malware. Con un investimento di **31.000 €**, pienamente conforme al budget assegnato (25.000 € – 35.000 €), l'infrastruttura e-commerce raggiunge un elevato livello di resilienza operativa, tutelando la continuità del business e proteggendo l'azienda da gravissimi danni economici e reputazionali.